

PART 5 OF 18

Runtime AI Security

Execution Interception, Behavioral Monitoring, Approval Gates, Circuit Breakers, Incident Recovery, and Kubernetes-Analogous Patterns

ENTERPRISE AI CONTROL ARCHITECTURE

Implementation Guide for Production AI Systems • 2026

5.1 Runtime Security Paradigm for AI Agents

Runtime security for AI agents addresses the class of threats that emerge during live execution and cannot be prevented through static analysis, pre-deployment testing, or policy configuration alone. Runtime threats include: behavioral drift from baseline, adversarial manipulation of in-progress sessions, cascading failures in multi-agent workflows, and emergent harmful patterns from combinations of individually safe actions.

Runtime Security Principle: No pre-deployment control is sufficient. The threat surface expands during execution as the agent accumulates context, interacts with external systems, and makes decisions with compounding consequences. Runtime controls are not a backup—they are an essential primary defense layer.

5.2 Execution Interception Architecture

5.2.1 The Action Interception Pipeline

Every agent action must pass through an interception pipeline before execution. The pipeline evaluates actions synchronously (for low-latency blocking decisions) and asynchronously (for complex behavioral analysis). The architecture mirrors Kubernetes admission controllers but operates on semantic agent actions rather than API server requests.

Stage	Operation	Blocking?	Max Latency	Action on Reject
Schema Validation	Validate action format and parameter types	Yes	< 1ms	Return error to agent
Authorization Check	Verify action is within capability scope	Yes	< 5ms	Return DENY; log
Hard Constraint Check	Check against absolute prohibitions	Yes	< 5ms	Block + alert SOC
Semantic Risk Score	Score action intent and impact	Conditional	50ms	Queue for human review if high-risk
Behavioral Pattern Check	Compare to expected action distribution	Conditional	200ms	Alert + optional block
Rate Limit Check	Enforce per-action-type rate limits	Yes	< 1ms	Throttle; alert if sustained
Reversibility Assessment	Score irreversibility of action	Conditional	10ms	Require human approval if irreversible
Async Audit Log	Record action and all evaluation results	No	Async	N/A

5.3 Behavioral Monitoring

5.3.1 Baseline and Drift Detection

Behavioral monitoring requires establishing a baseline of expected agent behaviour for each agent type, task category, and operational context. Drift detection then continuously compares live behaviour against the baseline using statistical methods. Significant drift triggers alerts and may trigger automatic containment.

5.3.2 Behavioral Metrics

- **Action Type Distribution:** Frequency distribution of tool calls by type (read vs write vs external call)
- **API Endpoint Distribution:** Distribution of API endpoints accessed by the agent
- **Data Volume:** Volume of data read and written per session; anomalous spikes indicate potential exfiltration
- **External Call Rate:** Rate and diversity of calls to external services
- **Error Rate:** Frequency of authorization denials, tool errors, and exception conditions
- **Action Sequence Entropy:** Statistical entropy of action sequences; low entropy may indicate scripted/automated attack
- **Goal Consistency Score:** Semantic similarity between agent actions and stated task goal
- **Resource Acquisition Rate:** Rate at which agent requests new permissions or capabilities

5.4 Approval Gates and Human-in-the-Loop Controls

5.4.1 Approval Gate Design

Approval gates pause agent execution at defined decision points and require human authorization before proceeding. Effective approval gate design balances safety (comprehensive coverage) against operational efficiency (low reviewer burden). Gates must be designed so that the reviewer has sufficient context to make a meaningful decision—not just a rubber stamp.

Gate Type	Trigger Condition	Information Presented to Reviewer	SLA
Pre-action Gate	Action risk score > threshold	Action params, agent goal, prior actions, risk rationale	5 minutes
Impact Gate	Potential impact > defined threshold (e.g., > \$10k, > 1000 records)	Impact estimate, action details, data affected	15 minutes
Irreversibility Gate	Action reversibility score < threshold	Action details, consequences if not reversed, reversal procedure	30 minutes
Novel Action Gate	Action type not in training baseline	Action details, similar historical actions, risk assessment	15 minutes
Accumulated Risk Gate	Session cumulative risk score > threshold	Session summary, all prior actions, risk accumulation	Immediate
Policy Exception Gate	Action requires policy exception	Exception details, policy rationale, risk and alternatives	1 hour

■ **Reviewer Experience:** Human approvers need purpose-built decision support tools, not raw log dumps. The approval UI must present: clear statement of what the agent wants to do, why it believes this is necessary, what alternatives exist, what the consequences are, and a one-click approve/deny/modify workflow.

5.5 Circuit Breakers and Kill Switches

5.5.1 Circuit Breaker Patterns

Circuit breakers automatically halt agent execution when detected conditions indicate potential misalignment, compromise, or impending harm. Unlike approval gates (which pause execution for human review), circuit breakers immediately terminate or quarantine the agent without human intervention.

Circuit Breaker	Trigger	Action	Recovery
Hard Limit Breaker	Absolute policy violation detected	Immediate task termination	Manual human review required
Anomaly Breaker	Behavioral anomaly score exceeds critical threshold	Session pause; human notification	Human review and re-authorization
Cascade Breaker	Agent causing cascading failures in downstream systems	Agent isolation; downstream systems notified	Root cause analysis before re-enable
Rate Breaker	Request rate exceeds sustained abnormal threshold	Throttle to safe rate; alert	Automatic reset after observation period
Resource Breaker	Resource consumption exceeds quota	Pause execution; release resources	Automatic reset with quota increase approval
External Signal Breaker	Kill signal received from authorized principal	Immediate shutdown; state checkpoint	Manual authorization to restart

5.6 Checkpoint and Rollback Architecture

For long-running agent tasks, checkpoint and rollback capabilities enable recovery from detected issues without losing all prior work. Checkpointing captures: agent goal state, action history, memory state, acquired capabilities, and conversation context. Rollback restores a prior checkpoint and allows the agent to proceed with corrected instructions or modified constraints.

5.6.1 Checkpoint Triggers

- Time-based: checkpoint every N minutes for long-running tasks
- Milestone-based: checkpoint at each defined task milestone or phase boundary
- Risk-based: checkpoint before any action classified as high-risk or irreversible
- Human-intervention: checkpoint immediately when human approval is requested

- Anomaly-based: checkpoint when behavioral anomaly detected (enables forensic analysis)

5.6.2 Comparison with Kubernetes Admission Controllers

Concept	Kubernetes	AI Agent Equivalent
Admission Controller	Intercepts API server requests pre-admission	Action Interceptor intercepts agent actions pre-execution
Validating Webhook	Validates requests against policy; approve/reject	Policy Engine validates action semantics; approve/reject/queue
Mutating Webhook	Modifies requests to enforce policy (e.g., add labels)	Action Modifier adjusts action parameters to meet policy (e.g., reduce scope)
OPA Gatekeeper	Policy-as-code for K8s resources	OPA/Cedar policy engine for agent actions
Pod Security Policy	Restricts container capabilities	Execution Sandbox restricts agent OS capabilities
ResourceQuota	Limits resource consumption by namespace	Resource Quotas limit agent CPU, memory, API calls
NetworkPolicy	Controls pod network connectivity	Agent Network Policy controls egress to external endpoints